Feature: A client site installs the booking window without a token

From build-plan: feature 25c

Size: light - packaging and wiring across three repos, with one small piece of logic (the command's three refusals).

Branch: `feature/25c-a-client-site-installs-the-booking-window-without-a-token`

Status: verified

Goal

A client site gets the booking window from a file in its own repo, not from GitHub Packages, so its Vercel project needs no `NODE_AUTH_TOKEN` and nothing is public. One command in Booking CRM builds the window, packs it into one file and installs that file into a site. Face and Body and IA a la Orden move over. Why: every new client site needed Frank's GitHub token in Vercel (Face and Body's first deploy failed on it, Oct 26).

Decided by Frank, Oct 27: option B, a packed copy committed into each site. Option A, public npm, lost: it needs an npmjs account and puts the code and its name in public.

In scope

- **The package** (`packages/booking-component/package.json`): `"private": true` , so no `npm publish` can ever send it anywhere, public npm included; `prepack` runs the whole build with its checks, so every packed file is a fresh, checked build; `publishConfig` and `prepublishOnly` go, and `publish.npmrc` is deleted. Version `0.2.2` : the package's own `package.json` changes, so the packed file is not the published 0.2.1.
- **The command**, `npm run pack:site --workspace=@frankdmosquera/booking-component -- <site folder>` (`packages/booking-component/pack-into-site.mjs` , beside `check-dist-imports.mjs`). The folder is read from where the command was typed (`INIT_CWD`), so `../face-and-body` works from the repo root. It: 1. refuses a folder whose `package.json` does not list `@frankdmosquera/booking-component` (never drops a file into the wrong repo); 2. runs `npm pack` , which builds first (`prepack`); 3. refuses when the site's `vendor/` already holds this version's file with different bytes ("bump the version"): one version is always one build. The same bytes is a no-op; 4. copies the file to `<site>/vendor/frankdmosquera-booking-component-<version>.tgz` , deletes the older `frankdmosquera-booking-component-*.tgz` files there, and runs `npm install ./vendor/<file>` in the site, which writes `"file:vendor/<file>"` into its `package.json` and

lockfile; 5. prints what changed and that the site's commit is the site's own. It never commits or pushes anywhere.

- **Face and Body** (`face-and-body` , branch `chore/booking-window-from-a-file` off its clean `main`): the command run on it, its `.npmrc` deleted (it held only the GitHub Packages lines), its `AGENTS.md` install lines (213 to 216) rewritten for the file, one commit, pushed, so Vercel builds a preview of it.
- **IA a la Orden** (`agency-site-app`): the same move. Its folder sits on its own open feature `feature/12c-our-own-cards-on-real-times` (its spec waiting on Frank, 10 commits not pushed), so where this commit goes is the one open question below. It moves from 0.2.0 to 0.2.2, so ialaorden.com also gets 0.2.1's "check your spam" line on the booked screen, in Spanish.
- **Docs here**: `AGENTS.md` Commands (the publish lines and the `gh ... write:packages` note become the pack command; how a site installs it), the header of `packages/booking-component/index.ts` (installing from the file, no `.npmrc` , no token).
- The root `package-lock.json` records 0.2.2 (closes F-530, which had it at 0.2.0).

Out of scope

- Merging either site's branch into its `main` (a production deploy): Frank's yes, each, after this feature's review.
- Removing `NODE_AUTH_TOKEN` from the two Vercel projects, and revoking the classic token with `read:packages` : Frank's, after each site's merge; a redeploy then proves the site builds without it. Listed as the handover in the step report.
- Deleting the versions already on GitHub Packages: they harm nothing; deleting is Frank's call.
- Any change to the window itself.

Build loop

One step, light. After Frank's yes on this plan, 25c.1 runs straight through: build, tests and checks, tick the box, the build log, commit and push here and on Face and Body's branch. No step review; the independent review comes at `/complete` . The only stops: a line only Frank crosses (a merge, a Vercel setting, `main`), or the plan turning out wrong.

Build steps

- [x] **25c.1 Sites install the window from a file in their own repo.** The package changes, the command and its tests, Face and Body moved, IA a la Orden moved (where the open question says), the docs.
  Done when:
  - Booking component tests pass, with new ones for the command's three rules: a folder without the window in its `package.json` refused; the same version with different bytes refused; the same bytes left alone and older files removed.

- Booking component build passes; `npm publish --workspace=@frankdmosquera/booking-component --dry-run` refuses (private).
- In each site, with `NODE_AUTH_TOKEN` unset and an empty npm cache (`npm ci --cache <empty folder>`), the install succeeds, `node_modules/@frankdmosquera/booking-component/package.json` says 0.2.2, and `npm run build` passes.
- Face and Body's pushed branch gets a Vercel preview build that is Ready, with no `.npmrc` in the repo.
- **Amended Oct 27, while building:** Face and Body's Vercel previews have never been Ready: `NEXT_PUBLIC_IMAGEKIT_URL_ENDPOINT` and `NODE_AUTH_TOKEN` are Production only, so every preview stops at `next build` (its feature 11 preview `3b278ea` too). The preview of `8c9a68f` ran with no token and installed the window, then stopped on ImageKit: that is the Vercel proof here. A Ready build comes with the production deploy after the merge.

Files / areas

- `packages/booking-component/package.json` , `pack-into-site.mjs` (new) and its test, `publish.npmrc` (deleted), `index.ts` (header only)
- `AGENTS.md` (Commands: the booking component lines)
- `package-lock.json` (root)
- `face-and-body` : `vendor/` (new), `package.json` , `package-lock.json` , `.npmrc` (deleted), `AGENTS.md`
- `agency-site-app` : the same five

Data / contracts

- File name: npm pack's own, `frankdmosquera-booking-component-<version>.tgz` , in `vendor/` at the site's root, committed. Only the newest one stays.
- A site's dependency: `"@frankdmosquera/booking-component": "file:vendor/<file>"` . Its lockfile holds the file's integrity, so Vercel's install fails loudly if the file and the lock disagree.
- What a site imports is unchanged: `BookingProvider` , `BookNowTrigger` and `@frankdmosquera/booking-component/booking-component.css` .

Testing

- `npm run test --workspace=@frankdmosquera/booking-component` , with the new tests on the command's decision (folder check, same version check, cleanup), kept apart from the parts that run npm so they test without a network.
- The clean-install and build checks in each site are run by hand and written in the step's log.

Notes for the AI

- `npm` on Windows is `npm.cmd`: start it through a shell from the script.
- A Vercel preview's state: `gh api repos/frankdmosquera/face-and-body/commits/<sha>/status`.
- Stage exact paths only, in every repo.
- Never push `agency-site-app`'s branch: its 10 unpushed commits are another session's work.

Open questions

- **Where IA a la Orden's move is committed.** (A, recommended) on its open branch `feature/12c-our-own-cards-on-real-times`, as the workspace rule says small chores ride on the open feature branch: one commit, not pushed (its other commits are not ours), so it goes online when that branch merges. (B) wait until its 12c is merged, then its own `chore/booking-window-from-a-file` branch. Either way its Vercel proof comes after this step.

Implementation walkthrough

The package (packages/booking-component/package.json). Version 0.2.2 and `"private": true`, so `npm publish` skips it and it can never reach any registry, public npm included. `prepack` runs the whole build with its checks, so every packed file is a fresh, checked build. `publishConfig`, `prepublishOnly` and `publish.npmrc` are gone. The root `package-lock.json` records 0.2.2 in the same commit (F-530).

The command (packages/booking-component/pack-into-site.mjs). `npm run pack:site --workspace=@frankdmosquera/booking-component -- ../face-and-body`, the folder read from where it was typed (`INIT_CWD`). It first refuses a folder whose `package.json` does not list the window, before any build (F-548). Then `npm pack` into a temp folder, the decision, the copy into the site's `vendor/`, `npm install ./vendor/<file>` in the site, and only once that succeeds the older packed files are removed (F-549). It never commits.

The decision (packages/booking-component/decide-pack-into-site.ts). Kept apart from npm and the disk so it is tested without either: a folder that does not use the window is refused; the same version with different bytes is refused ("bump the version"), so one version is always one build; the same bytes is left alone; only older packed files are removed. Three tests in `decide-pack-into-site.test.ts`. The `.mjs` imports this `.ts` file directly, which Node 26 (pinned in `.node-version`) runs by stripping types.

The sites. Face and Body on its own branch `chore/booking-window-from-a-file` (8c9a68f, pushed): `.npmrc` deleted, the dependency is `file:vendor/frankdmosquera-booking-component-0.2.2.tgz`, the lockfile holds the file's integrity, its AGENTS.md install lines rewritten. IA a la Orden on its open branch `feature/12c-our-own-cards-on-real-times`, not pushed: the same move, from 0.2.0, but another session's commit a1b73d0 took the `.npmrc`, `package.json`, lockfile and `vendor/` changes along with its own 12c work, so 25c's own commit there, 15c714d, holds only the AGENTS.md line. Both packed files are byte-identical to what this repo's build packs today.

Proof. Booking component tests (19 files, 101 tests), its build and formatting pass; the publish dry run skips the package as private. In each site, with no token and an empty npm cache, `npm ci` installed 0.2.2 and `npm run build` passed. Face and Body's Vercel preview installed the window with no token and then stopped on ImageKit, which, like the token, is set for Production only there; a Ready build comes with the production deploy after the merge (the spec's amended Done when).

Docs. AGENTS.md's Commands now name the pack command in place of the publish and install lines; the header of `index.ts` says sites install from the file in `vendor/`, no registry or token.

Left for Frank, after this merge. Merging Face and Body's branch (its production deploy) and IA a la Orden's 12c branch; removing `NODE_AUTH_TOKEN` from both Vercel projects and redeploying to prove they build without it; revoking the classic `read:packages` token; optionally adding the ImageKit address to Face and Body's Preview environment so its previews finish.

Reviewed twice. The first independent review (ab4bdd1) passed with F-548 and F-549, both fixed in cb587fc; the second (cb587fc) passed and closed them with F-530.

Carried. F-550 (P3): `pack:site` reads every entry in the site's `vendor/` in full, so a subfolder there stops it with EISDIR after the build; filtering by the packed-file name first fixes it. F-551 (P3): this spec's Open questions still reads as open; it was answered on Oct 27 with option A (IA a la Orden's move on its open branch), and the split of that move across a1b73d0 and 15c714d is recorded above.

Findings

25c/F-530 [P3] closed - The package goes to 0.2.1 but the lockfile still records the workspace at 0.2.0

File: package-lock.json:15990; packages/booking-component/package.json:3 **Found:** 2026-10-27 by /audit independent current (scope: 62e87d7..20d0bec; lenses: quality, security, performance, tests) **Why it matters:** 8904a15 bumps `@frankdmosquera/booking-component` to 0.2.1 without the root lockfile, whose `packages/booking-component` entry still says 0.2.0. Nothing breaks now: publishing reads `package.json`, and a scratch workspace with the same mismatch passed `npm ci` (npm 11.19.0) without touching the lock. But the next `npm install` on any machine rewrites that line, so an unrelated later commit carries this release's version change. The 0.2.0 bump (296314a) lagged the same way until the npm audit fix (787ef0d) picked it up. **Suggested fix:** Update the lockfile with the bump (`npm install --package-lock-only` from the root, which needs no new package) in this fix's commit, and do it with every version bump. **Resolution:** fixed 2026-10-27 in 25c (c2e0d1c): the root lockfile records the workspace at 0.2.2, in the same commit as the bump; the 25c independent review (ab4bdd1) saw it repaired. Closed 2026-10-27 by /audit independent current (fresh subagent, a0f2f86..cb587fc): package.json and the root lockfile's `packages/booking-component` entry both say 0.2.2; the lockfile records no `private` for any workspace (frontend and shared are private too), so the new `"private": true` needs no lock change.

25c/F-548 [P3] closed - pack:site refuses a folder that does not use the window only after a full build and pack

File: packages/booking-component/pack-into-site.mjs:37-58 **Found:** 2026-10-27 by /audit independent current (scope: a0f2f86..ab4bdd1; lenses: quality, security, performance, tests) **Why it matters:** The spec orders the command as "1. refuses a folder whose package.json does not list the window; 2. runs npm pack". The script runs `npm pack` (prepack, so the shared build, the backend route types, tsc, tsdown and the import check) first and only then asks `decidePackIntoSite` about the folder. Run against a throwaway folder whose package.json lists only `next`, it printed `npm notice filename: frankdmosquera-booking-component-0.2.2.tgz` before "Not installed ... does not list @frankdmosquera/booking-component". Nothing is written to the wrong folder, so the guard holds; a mistyped folder just costs a full build before the refusal, and the code no longer matches the spec's order. **Suggested fix:** Read the site's package.json and refuse before `npm pack` (the folder rule needs no bytes); keep the same-version check after the pack. Or amend the spec's order to say the folder is checked after the pack. **Resolution:** fixed 2026-10-27: pack-into-site.mjs asks `refuseNotASite` before `npm pack`, so a folder that does not use the window is refused with no build (a throwaway folder listing only `next`: the refusal printed in under a second, no `npm notice filename`); `decidePackIntoSite` keeps the same rule, still covered by its test. Closed 2026-10-27 by /audit independent current (fresh subagent, a0f2f86..cb587fc): `refuseNotASite` runs at pack-into-site.mjs:34-38, before `npm pack` at :43; run against throwaway folders, one listing only `next` and one with no package.json were each refused in under a second with no build output.

25c/F-549 [P3] closed - Older packed files are deleted before the site's npm install has succeeded

File: packages/booking-component/pack-into-site.mjs:62-64 **Found:** 2026-10-27 by /audit independent current (scope: a0f2f86..ab4bdd1; lenses: quality, security, performance, tests) **Why it matters:** The command copies the new file, removes every older `frankdmosquera-booking-component-*.tgz` from the site's `vendor/`, and only then runs `npm install ./vendor/<file>`. If that install fails (no network for hono or zod, a peer conflict), the site's package.json and lockfile still name the old `file:vendor/...-0.2.1.tgz`, which is now gone, so the site's next `npm ci` fails until the command is rerun or the file is restored from git. Recoverable (rerunning finishes the job, and git still holds the old file), but the order leaves the site broken in between. **Suggested fix:** Run the `npm install` first and remove the older files only after it succeeds. **Resolution:** fixed 2026-10-27: pack-into-site.mjs runs the site's `npm install` first and removes older packed files only after it succeeds, so a failed install leaves the old file the site still names. Closed 2026-10-27 by /audit independent current (fresh subagent, a0f2f86..cb587fc): the install runs at pack-into-site.mjs:69 and the removals at :70, and `execSync` throws on a failed install, so the older files the site still names stay; a rerun is safe because the packed file is reproducible (a fresh pack matched both sites' committed 0.2.2 files byte for byte).

Independent review

Status: passed **Target commit:** cb587fc52846a548294153c066dcba0f45b16bfb **Base commit:** a0f2f86cc726bde3005eaf1b816b44ec039068ec **Base ref:** main **Spec hash:** 9c39247536326306e6c715945ba018adec5dca3682c2467b8eb0deaa3ad68d14 **Prepared by:** claude **Builder model:** claude-opus-5-5 **Requested reviewer:** claude **Requested model:** claude-opus-5-5 **Requested execution:** automatic **Requested at:** 2026-10-27T19:32:40Z **Workflow:** regular **Check required:** no **Reviewer adapter:** claude **Reviewer model:** claude-opus-5-5 **Reviewer context:** fresh subagent **Actual execution:** automatic **Reviewed at:** 2026-10-27T19:40:00Z **Scope:** current **Lenses:** quality, security, performance, tests **Verdict:** passed **Check result:** not-required

Commands

- `npm run test --workspace=@frankdmosquera/booking-component` : pass (builds first; 19 files, 101 tests)
- `npm run build --workspace=@frankdmosquera/booking-component` : pass (tsc, tsdown, dist import check)
- `npm run format:check` : pass
- `npm publish --workspace=@frankdmosquera/booking-component --dry-run` : pass (exit 0, "Skipping workspace @frankdmosquera/booking-component, marked as private"; nothing would be sent)
- `npm run pack:site --workspace=@frankdmosquera/booking-component -- <throwaway folder>` : refusal paths only, deleted afterwards (no argument, no package.json, only `next` , different bytes under 0.2.2, a subfolder in vendor/); success path not run by instruction

Evidence

- Freshness: HEAD is cb587fc; `git merge-base main cb587fc` is a0f2f86; spec SHA-256 matches; only `.env.example` (excluded by the owner's note) and `blueprint/context/review.md` differ from the target.
- A fresh pack (dry run shasum 603e6ead46a2265071ff709382e96070e08fc3e7) is byte-identical to the committed 0.2.2 file in face-and-body 8c9a68f and agency-site-app a1b73d0, and both sites' lockfiles carry its sha512, so the build is reproducible and the "same bytes is a no-op" rule holds in practice.
- The packed file holds 4 files (dist/index.js, dist/index.d.ts, the CSS, package.json); no source, test or secret ships.
- pack:site refused a folder without the window, and one with no package.json, in under a second with no build (F-548); refused a different 0.2.2 build with "bump the version" and wrote nothing; ran the site install before removing older files (F-549).
- Root lockfile and package.json both say 0.2.2 (F-530).
- Both sites: no `.npmrc` , dependency `file:vendor/frankdmosquera-booking-component-0.2.2.tgz` , AGENTS.md install lines rewritten; face-and-body branch in sync with its origin. Sibling repos read only.

- No path or shell injection: the site folder is only a `cwd`; the command strings hold a temp folder and a name built from the package's own version.

Findings

- F-530 closed, F-548 closed, F-549 closed
- F-550 [P3] open: pack:site reads every vendor/ entry in full and crashes on a subfolder there
- F-551 [P3] open: the spec still lists where IA a la Orden's move is committed as open, and does not record the split across a1b73d0 and 15c714d

Remaining risk

- The pack:site success path (the site's `npm install`) was not run by this review, by instruction; the builder's log records it on both sites.
- The clean installs with no token and an empty npm cache, and the sites' builds, were not rerun here (installs in the sibling repos were out of bounds); the matching lockfile integrity is the evidence instead.
- No Vercel build is Ready yet for either site: face-and-body previews lack Production-only variables, and agency-site-app's branch is unpushed; the token removal in Vercel and the merges are Frank's, after this feature.
- `npm publish --workspace` skips a private package with a warning and exit 0 rather than an error; a plain `npm publish` from the package folder would error. Either way nothing is published.
- The Audit skill's dashboard activity (`blueprint/.state/run.json`) was not written, because this reviewer was limited to the two review files.